

Lumen Asset LCM

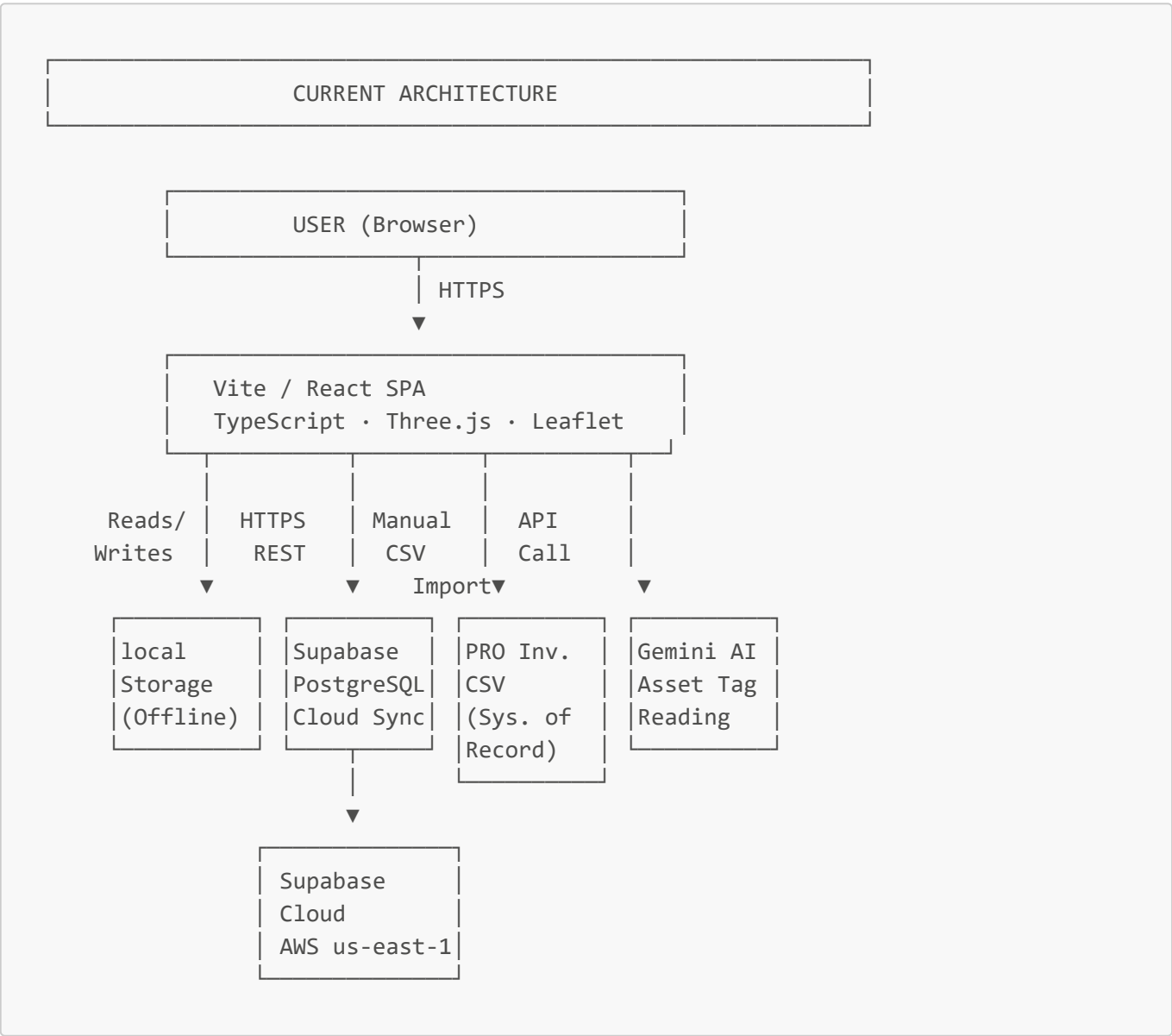
Architecture Brief & Commercialisation Roadmap

Prepared for: Internal Management Review **Date:** February 2026 | **Version:** 1.0

1. Current Architecture (As-Built)

What it is today

Lumen Asset LCM is a **browser-based, single-page application (SPA)** built with modern web technology. It runs entirely client-side — meaning no dedicated application server is required to operate it.



Technology Stack

Layer	Technology	Notes
-------	------------	-------

Layer	Technology	Notes
Frontend	React 19 + TypeScript	SPA, no dedicated backend
3D Viewer	Three.js	In-browser WebGL rendering
2D Maps	Leaflet.js	Site plan overlay
PDF Viewer	PDF.js	Floor plan rendering
Cloud Persistence	Supabase (PostgreSQL)	Single workspaces table
Offline Storage	Browser localStorage	Fallback / primary cache
AI	Google Gemini API	Optional asset tag reading
Build	Vite 6	Fast ESM dev + prod build

Current Data Flow

1. User opens the app — workspace loads from **Supabase** (or **localStorage** if offline)

2. Sites, buildings, racks, equipment and 4D status are persisted in a **single JSON blob**

3. PRO Inventory is imported via **manual CSV upload** each session

4. Reconciliation instructions are exported as **JSON / TXT files** for manual handoff

Current Limitations (Honest Assessment)

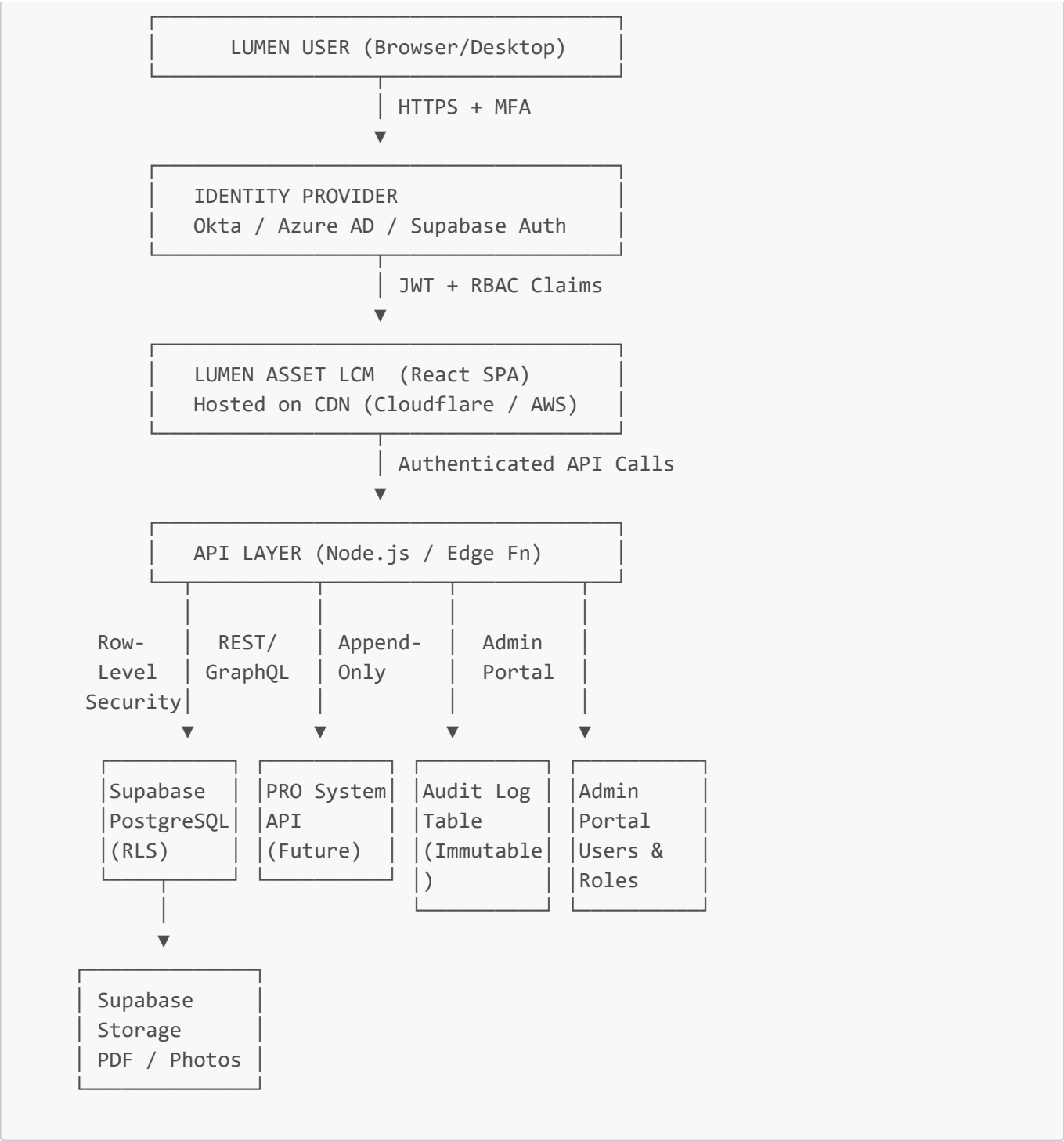
!

[CAUTION] The following gaps must be addressed before any enterprise deployment.

Gap	Risk
No user authentication — any URL visitor can access any workspace	Critical
Single shared workspaces table — no row-level tenant isolation	Critical
Supabase anon key visible in the browser — grants direct DB access	High
No audit log of who changed what and when	High
No role separation (viewer vs. editor vs. admin)	High
All data in a single JSON blob — not queryable or reportable	Medium
No MFA	High
No data residency controls	Medium
Manual CSV workflow — no live PRO system integration	Medium

2. Target Architecture (Enterprise-Ready)

TARGET ENTERPRISE ARCHITECTURE



3. Commercialisation Roadmap

Phase 1 — Authentication & Identity (Weeks 1–4)

"Lock the front door"

Task	Detail
Enable Supabase Auth	Email / password login as baseline
Add OAuth 2.0 / SSO	Integrate with Lumen's identity provider (Okta or Azure AD / Entra ID)
Implement MFA	TOTP (authenticator app) or email OTP — mandatory for all users

Task	Detail
Session management	Configurable token expiry, forced re-auth on inactivity
Secure the anon key	Move all DB interactions behind authenticated Edge Functions

Outcome: Only credentialed, MFA-verified Lumen users can access the application.

Phase 2 — Role-Based Access Control (Weeks 3–6)

"Right person sees right data"

Role	Permissions
Viewer	Read-only access to assigned sites
Technician	Create / update racks and equipment; import CSV
Analyst	Full inventory reconciliation; export instructions
Site Admin	Manage users for their sites; approve changes
Platform Admin	Full system access; tenant management

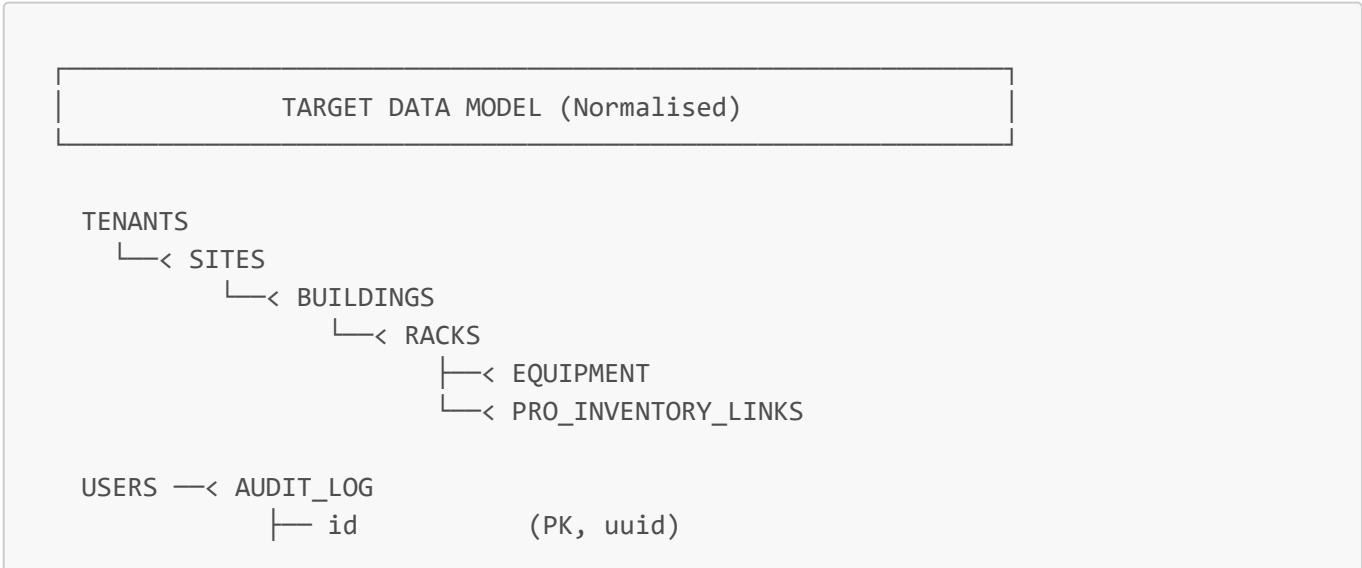
- Implement **Row-Level Security (RLS)** in PostgreSQL — users can only query rows belonging to their tenant / site
- Store roles in a `user_roles` table, enforced at the database level (not just UI)
- Audit all role assignments with timestamp + actor

Outcome: A Lumen regional manager cannot see another region's data, even with a direct API call.

Phase 3 — Data Model Normalisation & Audit Logging (Weeks 5–10)

"Replace the JSON blob with a proper schema"

Currently all workspace data is stored as a single JSON document, which cannot be queried, reported on, or audited. The target schema:



USERS —< AUDIT_LOG

id

(PK, uuid)

—	user_id	(FK → USERS)
—	action	(CREATE / UPDATE / DELETE)
—	entity_type	(RACK / EQUIPMENT / SITE ...)
—	entity_id	(FK → affected record)
—	before_snapshot	(JSON – previous state)
—	after_snapshot	(JSON – new state)
—	created_at	(timestamp, immutable)

Deliverable	Detail
Normalised schema	Sites, Buildings, Racks, Equipment as individual rows
Immutable audit log	Every create / update / delete recorded with before/after snapshot
Soft deletes	Records flagged deleted_at — not physically removed
Change attribution	Every row carries created_by, updated_by, updated_at
Migration tooling	Script to import existing JSON workspace blobs into new tables

Outcome: Full traceability of every inventory change — who, what, when, and from what value.

Phase 4 — Security Hardening & Compliance (Weeks 8–14)

"Pass enterprise procurement review"

Requirement	Implementation
Data at rest	AES-256 encryption (Supabase default on AWS RDS)
Data in transit	TLS 1.2+ enforced — no HTTP fallback
Data residency	Supabase region selection (US, EU, APAC)
Penetration testing	Certified third party (CREST / OWASP) — API and SPA surface
OWASP Top 10	Code audit against injection, XSS, CSRF, broken auth, IDOR
Secrets management	All keys in environment variables / Vault — none in source code
Dependency scanning	Automated CVE scanning on npm packages (Snyk / Dependabot)
SOC 2 Type II	Supabase is SOC 2 Type II certified — include in vendor docs
CSP Headers	Content Security Policy, HSTS, X-Frame-Options on hosted SPA
API rate limiting	Prevent credential stuffing and bulk data exfiltration
SIEM integration	Forward audit logs to Lumen's SIEM (Splunk / Elastic) via webhook

Phase 5 — Integration & Scalability (Weeks 12–20)

"Connect to the ecosystem"

Integration	Value
Live PRO System API	Replace manual CSV import with automated delta sync
SSO with Lumen IdP	Users log in with Lumen corporate credentials
Reporting API	REST endpoints for Lumen's BI tools (PowerBI, Tableau)
Webhook / Event Bus	Push reconciliation completions to ServiceNow
CDN Hosting	Cloudflare or AWS CloudFront — global performance + DDoS protection
Disaster Recovery	Daily automated Supabase backups + Point-in-Time Recovery (PITR)
SLA / Uptime	Supabase Pro plan: 99.9% uptime SLA + 24/7 support

4. Effort & Cost Estimate (Indicative)

Phase	Estimated Dev Effort	Supabase Tier
Phase 1 — Auth & MFA	3–4 weeks (1 dev)	Pro (\$25/mo)
Phase 2 — RBAC	3–4 weeks (1 dev)	Pro
Phase 3 — Data Model	4–6 weeks (1–2 devs)	Pro
Phase 4 — Security	4–6 weeks + 3rd party pentest	Pro / Team
Phase 5 — Integration	6–10 weeks (2 devs)	Team (\$599/mo)
Total	~6–8 months	~\$600–1,200/mo infra

[!NOTE] A dedicated security consultant for Phase 4 is strongly recommended — typically adds 2–4 weeks and \$15–30K USD to the programme.

5. Key Questions Lumen Procurement Will Ask

Question	Today → Target
How is user identity verified?	No auth → SSO + MFA via Okta/Azure AD
Is our data isolated from other customers?	Shared blob → RLS row-level tenant isolation
Where does data reside?	AWS us-east-1 → Configurable region per contract
Who can see audit history?	None → Immutable audit log with SIEM export
Is the platform penetration tested?	No → Annual CREST pentest + CVE scanning
What is the data backup strategy?	None → Daily backup + PITR, 30-day retention
What is the uptime SLA?	None → 99.9% on Supabase Pro / Team

Question	Today → Target
Is the product SOC 2 compliant?	Not claimed → Supabase infra is SOC 2 Type II; app audit in progress

6. Recommended Immediate Actions

[!IMPORTANT] Before any Lumen pilot or commercial engagement, the following three items are non-negotiable.

- 1. **Enable Supabase Auth with MFA** — eliminates the most critical security gap within days
- 2. **Move to Row-Level Security** — ensures no cross-tenant data leakage
- 3. **Remove anon key from the client bundle** — place all mutations behind authenticated functions

These three steps can be completed in **2–3 weeks** and materially change the security posture in time for a Lumen security review.

Lumen Asset LCM — Management Briefing | Confidential | February 2026